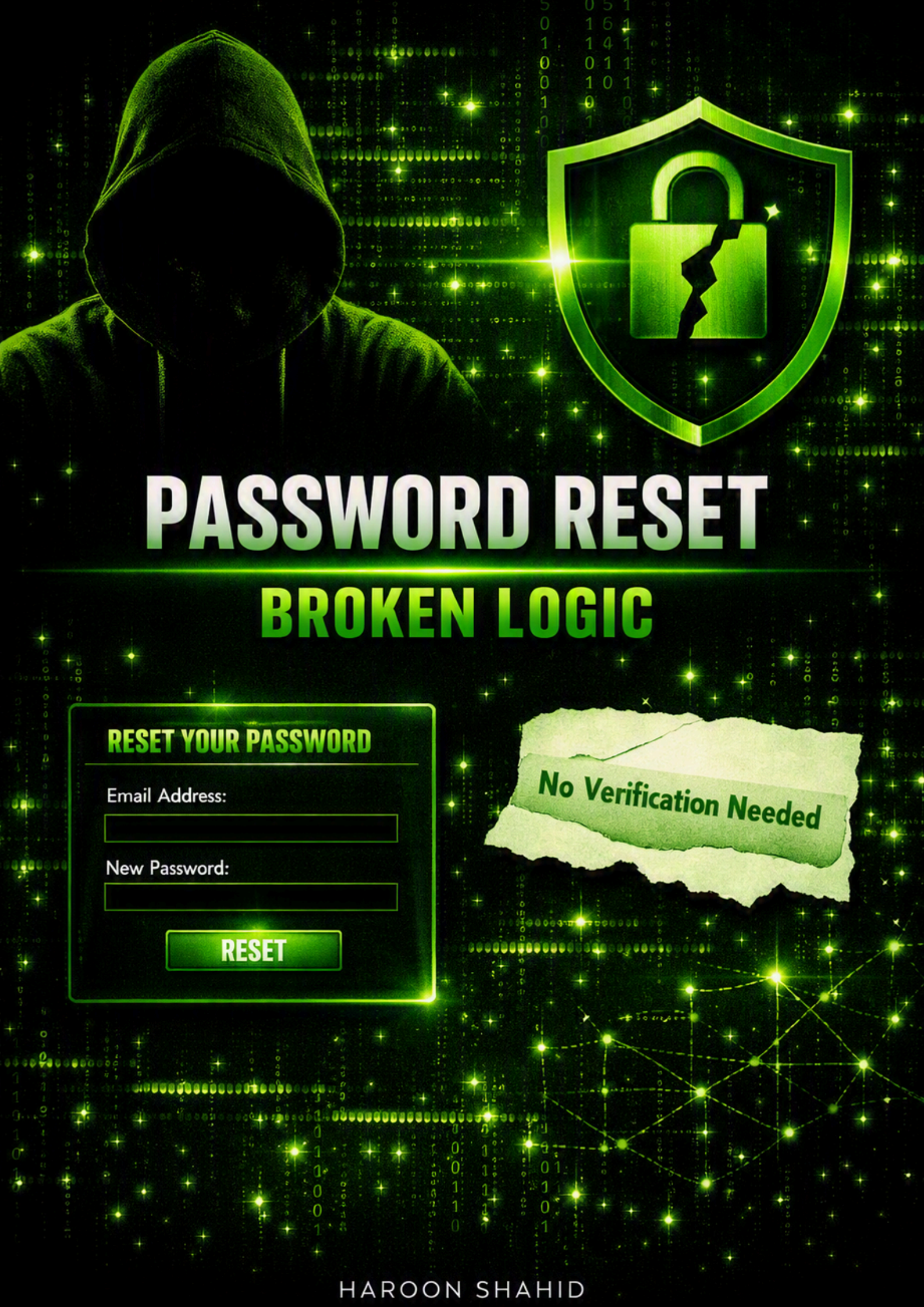




PASSWORD RESET

BROKEN LOGIC

RESET YOUR PASSWORD

Email Address:

New Password:

RESET

No Verification Needed

Lab: Password reset broken logic

If we have the username and not the password of the victim, and the password reset functionality is broken, we can change the password of the victim and log in as victim resulting in the full account takeover. To understand how to abuse the password reset functionality, we are gonna solve a Portswigger Lab.

=====

This lab's password reset functionality is vulnerable. To solve the lab, reset Carlos's password then log in and access his "My account" page.

- Your credentials: **wiener:peter**
 - Victim's username: **carlos**
- =====

Solution

Step 1:

Go to My account and click Forgot Password since the vulnerability is in the Forgot Password feature.

Home | **My account**

Login

Username

Password

Forgot password?

Log in

Step 2:

Then it will ask a username. Just enter your own username (**wiener**) and hit Submit.

Please enter your username or email

wiener

Submit

Step 3:

You will receive an email. Click on the **Email Client** to see the email containing Password Reset link.

Web Security Academy

Password reset broken logic

Back to lab home

Email client

Back to lab description >>

Please check your email for a reset password link.

Step 4:

Click on that link. You will be redirected to a page to change your Password.

Your email address is wiener@exploit-0a90006703c4931481ab49b501e50090.exploit-server.net

Displaying all emails @exploit-0a90006703c4931481ab49b501e50090.exploit-server.net and all subdomains

Sent	To	From	Subject	Body
2026-09-16 10:39:50 +0000	wiener@exploit-0a90006703c4931481ab49b501e50090.exploit-server.net	no-reply@0a54002203f4934481664ad3001f0015.web-security-academy.net	Account recovery	Hello! Please follow the link below to reset your password. https://0a54002203f4934481664ad3001f0015.web-security-academy.net/forgot-password?temp-forgot-password-token=0q816ahdv06gqsj98vbjnc1pe8wqn7ya Thanks, Support team

Step 5:

Enter a new password and confirm it. I entered **pass123** as the new password. Before you click Submit, open Burp Suite and turn Intercept On to capture the request.

New password

.....

Confirm new password

.....

Submit

DashboardTargetProxyIntruderRepeaterCollaboratorSequencerDecoderComparerLoggerOrganizerExtensionsDiscover

InterceptHTTP historyWebSockets historyMatch and replaceProxy settings

Intercept on

Forward

Drop

Step 6:

After the Burp is ready to intercept the requests, click on the Submit button. A password change POST request will be sent to the server.

DashboardTargetProxyIntruderRepeaterCollaboratorSequencerDecoderComparerLoggerOrganizerExtensionsDiscover

InterceptHTTP historyWebSockets historyMatch and replaceProxy settings

Intercept on

Forward

Drop

Request to https://0a54002203f4934481664ad3001f0015.web-security-a... Open browser

Time	Type	Direction	Method	URL	Status code	Length
03:47:10	1...	HTTP	→ Request	POSThttps://0a54002203f4934481664ad3001f0015.web-security-academy.net/forgot-password?temp-forgot-password-token=0q8l6ahdv0...		
03:47:11	1...	WS	→ To server	https://exploit-0a90006703c4931481ab49b501e50090.exploit-server.net/academyLabHeader		4
03:47:11	1...	WS	→ To server	https://0a54002203f4934481664ad3001f0015.web-security-academy.net/academyLabHeader		4
03:47:18	1...	WS	→ To server	https://0a54002203f4934481664ad3001f0015.web-security-academy.net/academyLabHeader		4
03:47:18	1...	WS	← To client	https://0a54002203f4934481664ad3001f0015.web-security-academy.net/academyLabHeader		4

Request

PrettyRawHex

1 POST /forgot-password?temp-forgot-password-token=0q8l6ahdv06gqsj98vbjnc1pe8wqn7ya HTTP/2
2 Host: 0a54002203f4934481664ad3001f0015.web-security-academy.net
3 Cookie: session=Eu0f0yq3udw7Q65MrSZPiCcNkonenoFs
4 Content-Length: 121
5 Cache-Control: max-age=0
6 Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99"
7 Sec-Ch-Ua-Mobile: ?0
8 Sec-Ch-Ua-Platform: "Windows"
9 Accept-Language: en-US,en;q=0.9
10 Upgrade-Insecure-Requests: 1
11 Content-Type: application/x-www-form-urlencoded

Inspector

Request attributes2
Request query parameters1
Request body parameters4
Request cookies1
Request headers24

Event log (3)

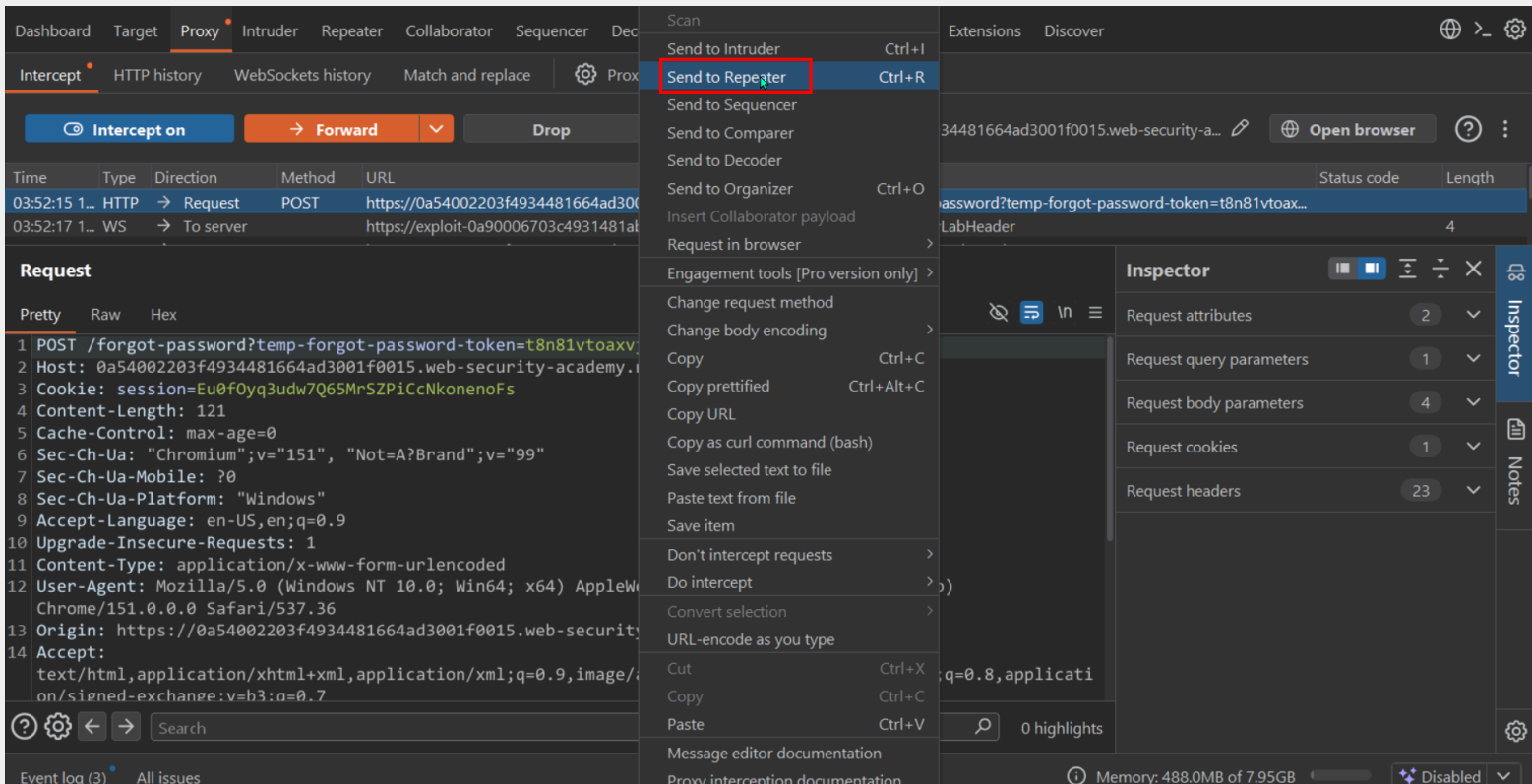
All issues

Memory: 488.0MB of 7.95GB

Disabled

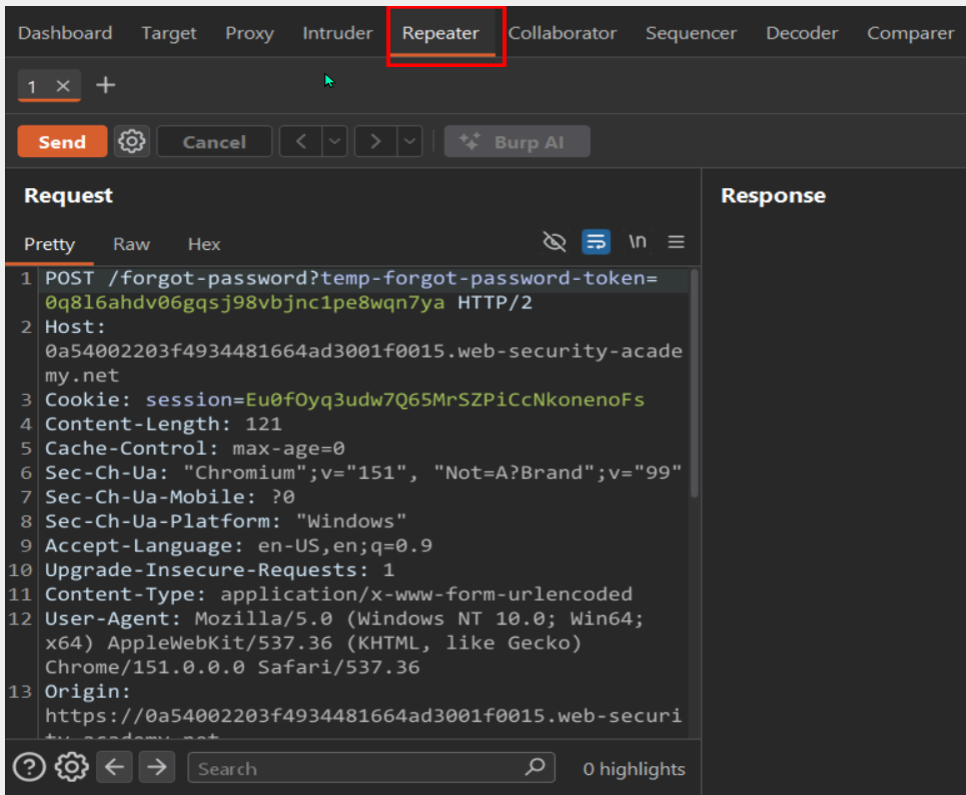
Step 7:

This request will be captured in the Intercept tab. Just right click on this request and send it to Repeater and now you can turn the Intercept Off.



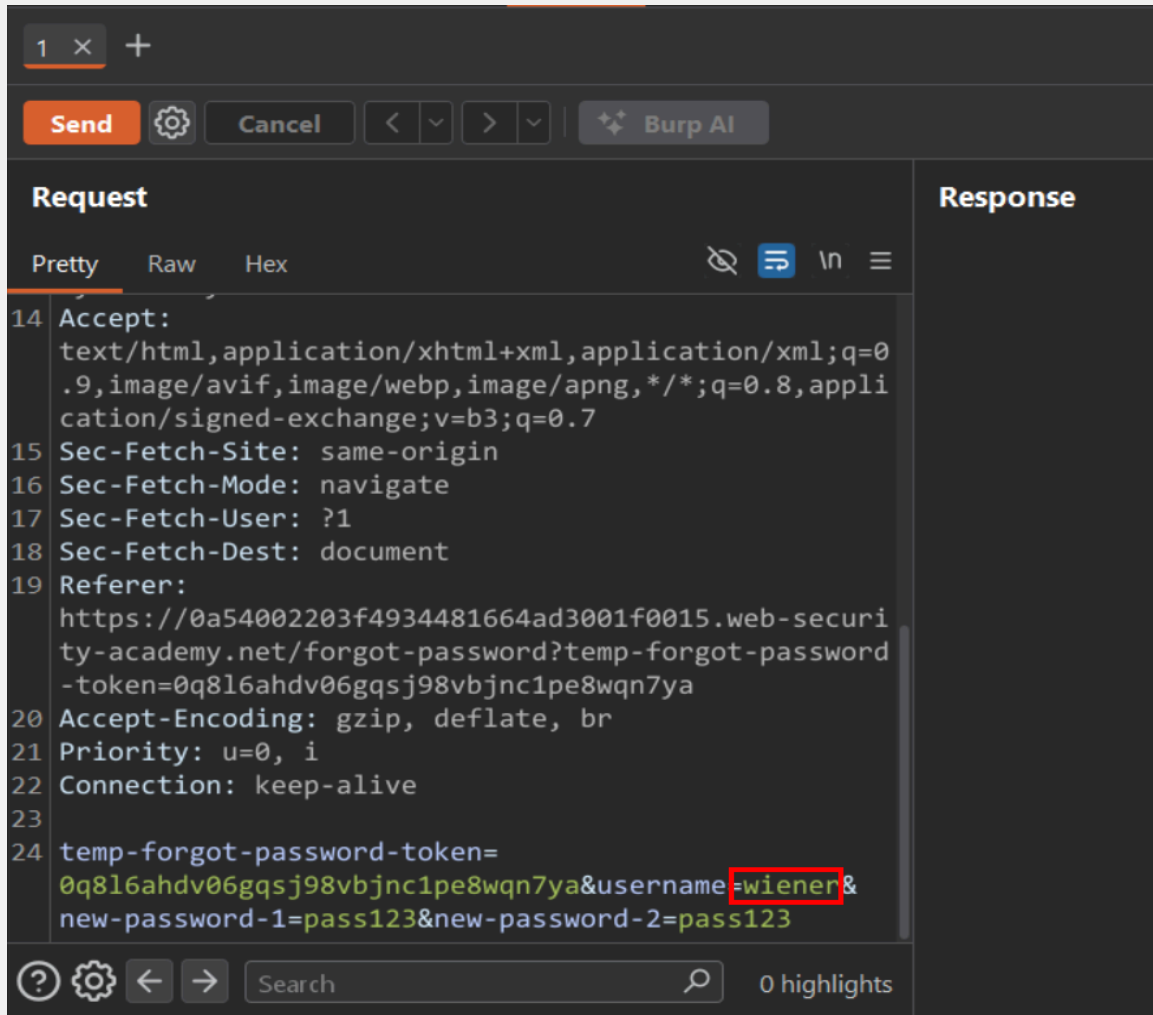
Step 8:

Go to the repeater and there you will see **wiener** in the request if you scroll down as we send a request from **wiener's account** for wiener Password Change.



Step 9:

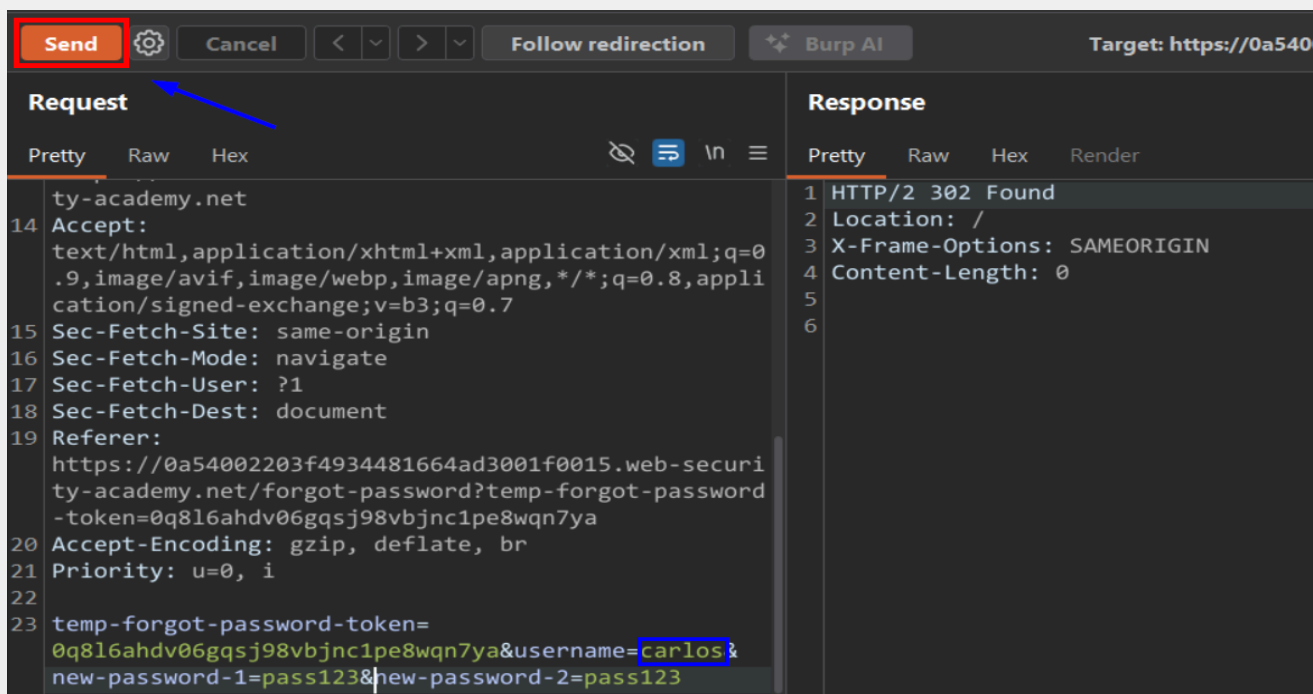
Just replace the wiener with carlos, and hit Send and that's it. This is actually the vulnerability in this feature that the **temp-forgot-password-token** is not verified on the server which allows me to change the Password of carlos by just replacing wiener with carlos. And in this way I abused Password Reset Broken Logic to change carlos' password and gained access to his account.



The screenshot shows the Burp Suite interface with a request tab selected. The request is a POST to `https://0a54002203f4934481664ad3001f0015.web-security-academy.net/forgot-password?temp-forgot-password-token=0q816ahdv06gqsj98vbjnc1pe8wqn7ya`. The request body contains the following parameters:

```
temp-forgot-password-token=0q816ahdv06gqsj98vbjnc1pe8wqn7ya&username=wiener&new-password-1=pass123&new-password-2=pass123
```

The word "wiener" is highlighted with a red box. The interface also shows the "Send" button and the "Response" tab.



The screenshot shows the Burp Suite interface with a request tab selected. The request is a POST to `https://0a54002203f4934481664ad3001f0015.web-security-academy.net/forgot-password?temp-forgot-password-token=0q816ahdv06gqsj98vbjnc1pe8wqn7ya`. The request body contains the following parameters:

```
temp-forgot-password-token=0q816ahdv06gqsj98vbjnc1pe8wqn7ya&username=carlos&new-password-1=pass123&new-password-2=pass123
```

The word "carlos" is highlighted with a blue box. The interface also shows the "Send" button and the "Response" tab. The response is a 302 Found status with the following headers:

```
HTTP/2 302 Found
Location: /
X-Frame-Options: SAMEORIGIN
Content-Length: 0
```

Step 10:

Click on My Account and in username enter carlos and in the password field enter the new password (**pass123** in my case) and click Log in to solve the lab.

Login

Username

carlos

Password

.....

[Forgot password?](#)

Log in

Congratulations, you solved the lab!

My Account

Your username is: carlos

Your email is: carlos@carlos-montoya.net

Email

Update email

In real testing, you can remove the token completely or replace the token with characters of the same length if not touching it completely is not working.

<https://www.linkedin.com/in/haroonshahid76/>

<https://github.com/haroon505>

=====